

RE026:

Name: Vasu

Food Remedy Project

Date: 19 September 2026

INTRODUCTION:

This research investigates safe and practical methods for distributing and testing a signed Android APK internally when Google Play testing access is unavailable or delayed. The purpose of this research is to provide the Food Remedy project with a fallback testing process that allows authorised team members to install and test an Android release candidate on physical devices. The process focuses on internal testing only and does not recommend public APK distribution. The research covers direct APK installation, Android security settings, the differences between APK and AAB files, security and privacy risks, authorised tester access, versioning practices and evidence that should be collected during physical-device testing. A signed APK is an installable Android application package. Android requires an APK to be digitally signed before it can be installed or updated, because the signature helps Android identify the application publisher and verify that later updates come from the same signing identity. A release APK should therefore be created using the approved release-signing process, and the private signing key or keystore must not be shared with testers.

INTERNAL APK DISTRIBUTION:

When Google Play testing is unavailable, a signed APK can be distributed directly to a limited group of authorised Android testers. The APK may be transferred using a controlled method such as a private project storage location, an approved file-sharing system or a direct USB transfer to a test device. The distribution method should be selected carefully because an APK may contain application code, configuration information and references to backend services. Before distributing the APK, the development team should confirm that the build is intended for internal testing and does not contain development-only settings, test credentials or unnecessary sensitive information. The team should also confirm that the APK has the correct application

package name, version name, version code and release configuration. The APK should be shared only with testers who have been approved by the project team.

The tester should receive the APK together with basic installation instructions, the build version, the expected testing period and a method for reporting problems. Testers should not upload the APK to public websites, public messaging groups or unrestricted file-sharing locations. If a tester is no longer involved in the project, access to the APK and related testing information should be removed where possible.

PRE-REQUISITES:

Before installing the Food Remedy APK, the following requirements should be checked:

- The tester must have a compatible Android device.
- The tester should understand that the build is for internal testing and may contain unfinished functionality.
- The device should have enough free storage for the APK and application data.
- The tester should confirm the file name, version name and version code.
- The tester should avoid entering unnecessary personal, health or food-profile information during testing.
- The APK should be signed using the expected application signing identity.
- The tester should have permission from the project team to install the application.
- The APK should be obtained from the approved project distribution location.
- The tester should have a reliable method for reporting installation problems, crashes and unexpected behaviour.

The team should also confirm that the Android application is configured to communicate with the correct testing backend. For example, the release candidate should not accidentally connect to an unintended production database or use development-only endpoints. This is particularly important for Food Remedy because the application may process nutritional information, user profiles, shopping lists and other user-related data.

PROCESS FOR INSTALLATION :

1. The tester receives the signed APK through the approved internal distribution method. The tester should not download APK files from unknown websites or from links shared outside the project team.
2. The tester should check the APK file name and compare it with the release information supplied by the project team. The release information should include the application name, version name, version code, build date and purpose of the build.
3. Android may block an APK if it has been obtained from a source that is not currently authorised to install applications. Depending on the Android version and the application used to open the APK, the tester may be asked to allow installation from that specific source. This permission should only be enabled for the source being used to install the approved APK. An example can be that, if the tester opens the APK using a file manager, Android may provide a setting for allowing that application to install unknown applications. The tester should enable the setting only when required, complete the installation and then disable the permission again if it is not needed.
4. The tester should open the APK file and follow the Android installation process it says. If Android displays a warning or something unusual, the tester should stop and confirm the source of the APK with the project team before continuing. The tester should not ignore warnings when the file source or application identity is uncertain.
5. After installation, the tester should open Food Remedy app and check whether the application starts correctly. The tester should record the application version, Android version, device model and any error messages. The tester should also confirm that the application can connect to the expected backend services and that the main testing features are available.
6. The tester should record whether installation was successful and report any problems to the assigned project contact. Problems can also include installation failure, incompatible Android versions, application crashes, authentication problems, or unexpected permissions.

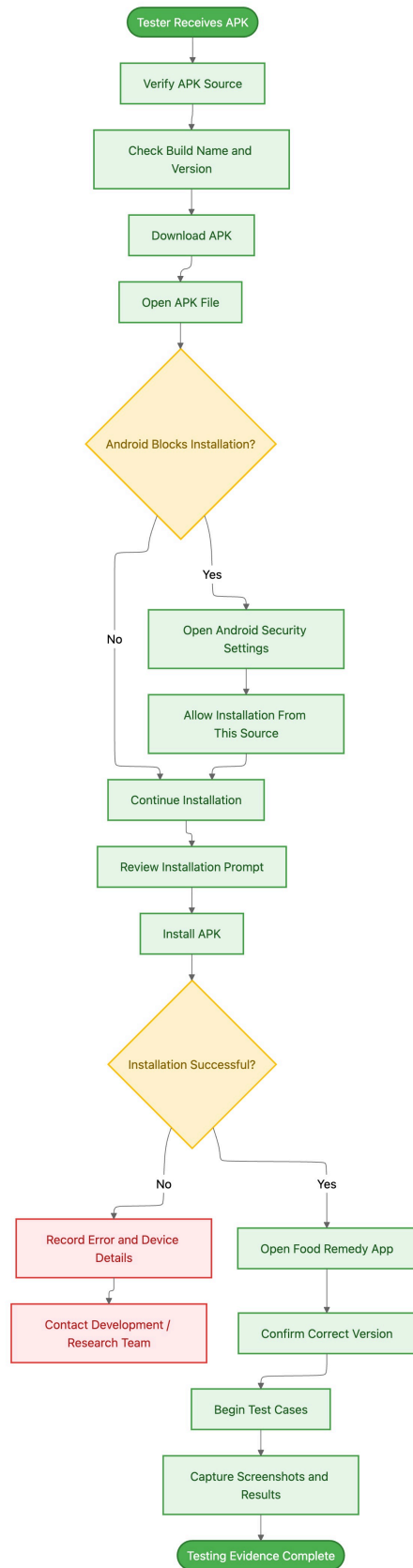


Fig 1 - APK installation flow

ANDROID SECURITY SETTINGS & GUIDE FOR USERS:

Android includes security controls to prevent applications from being installed from untrusted sources. Direct APK installation may therefore require the tester to approve installation from the application that opened the APK. The exact menu names may differ depending on the Android version and device manufacturer.

The tester should follow these general actions:

- ☐ Open the approved APK file.
- ☐ If Android displays a message that installation is blocked, open the relevant settings option.
- ☐ Find the permission relating to installing unknown applications.
- ☐ Identify the application being used to open the APK, such as a file manager or browser.
- ☐ Allow installation from that source only if the APK came from the authorised project distribution location.
- ☐ Return to the APK and complete the installation.
- ☐ Disable the permission again after installation if it is no longer required.
- ☐ Keep Google Play Protect and other normal Android security protections enabled.

The project team should not tell the testers to disable all Android security features. Disabling security protections can increase the risk of installing malicious or modified applications. The safer approach is to approve only the specific installation source for the short period required and to use a verified APK supplied by the project team.

APK v/s AAB

An APK and an AAB are different Android application package formats. An APK is the package that can be installed directly on an Android device. An Android App Bundle, referred to as AAB, is mainly a publishing format that is uploaded to Google Play or

another supported distribution service. An AAB cannot normally be installed directly on an Android device without first being processed into installable APK files.

Feature	APK	AAB
Full name	Android Package	Android App Bundle
Main purpose	Installation and distribution of an Android application	Publishing and distribution through an app store
Direct installation on a device	Yes, if the APK is compatible and signed	No, not directly
Suitable for direct internal sideloading	Yes	No, unless converted into installable APKs
File extension	.apk	.aab
Distribution method	Direct transfer, controlled file sharing or an app store	Usually uploaded to Google Play or another supported store
Device-specific delivery	The APK may contain the required application resources for a target device	The distribution service can generate suitable APKs for different device configurations
Main benefit	Simple for direct installation and physical-device testing	Allows distribution services to optimise delivery for different devices
Main limitation	The team must manage the correct APK and its distribution securely	It requires a compatible distribution process before testers can install the application

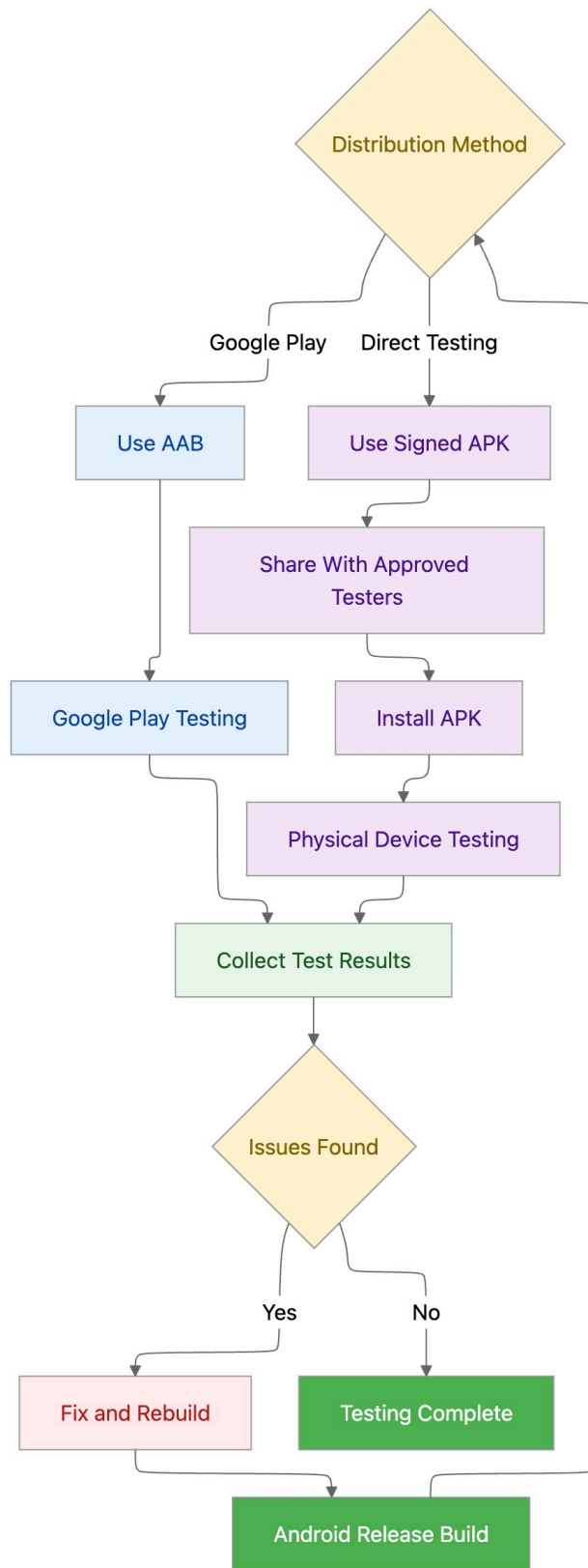


Fig 2- APK vs AAB

For the Food Remedy fallback process, a signed APK is more suitable than an AAB because the goal is to install the application directly on authorised physical Android devices. If the project later uses Google Play internal testing, the team may use an AAB because Google Play can generate and deliver the appropriate APKs to testers.

SECURITY RISKS AND AFFECT TO PRIVACY:

Direct APK distribution creates several security and privacy risks. The first risk is unauthorised redistribution. Once a tester receives an APK, the file may be copied or forwarded to people outside the project. This can expose unfinished application functionality and may allow unauthorised people to inspect or use the application. Another risk is APK modification. An APK may be altered after it has been built, and a modified file may contain unwanted code or changed configuration. Testers should therefore obtain the APK only from an approved location and should confirm the build identity before installation. The team may also provide a checksum or other file-verification value so that testers can compare the received file with the approved release candidate. There is also a risk of exposing sensitive configuration information. The APK should not contain private signing keys, passwords, service-account credentials or unnecessary secrets. The team should review environment variables and release configuration before building the APK. Backend access should be controlled through appropriate authentication and authorisation rather than relying only on the fact that the APK is distributed privately.

Food Remedy may process user profiles, nutritional information, shopping lists and other personal data. Testers should use test accounts and test data wherever possible. They should avoid entering real personal information unless it is necessary and has been approved for the testing activity. Test data should be removed or reset after testing when appropriate.

A further risk is installing an incompatible or incorrectly configured build. One example can be, the APK might use the wrong API endpoint, an incorrect Firebase configuration or an unsuitable database environment. This could cause failed testing or unintended changes to data. Each build should therefore be clearly identified and checked before it is distributed.

RECOMMENDATION FOR THE SECURITY CONTROL:

Risk	Recommended control
APK shared with unauthorised people	Use a private distribution location and approved tester list
APK modified during transfer	Use a checksum or other file-verification method
Installation of an unknown file	Distribute APKs only through approved project channels
Exposure of private keys	Keep signing keystores and private keys with authorised developers only
Exposure of personal information	Use test accounts and avoid real personal data
Incorrect backend connection	Check release configuration and API endpoints before distribution
Unclear build identity	Use a consistent version name, version code and build identifier
Old or vulnerable build remaining installed	Record the build version and remove outdated test builds when necessary
Public redistribution	Include internal-use instructions and prohibit forwarding
Security settings left enabled unnecessarily	Disable installation permission after installation if it is no longer needed
Unreported testing problems	Provide a clear issue-reporting process and evidence checklist

ONLY AUTHORISED USERS ALLOWANCE:

The APK should be distributed only to testers who have been approved by the Research Team, Development Team or relevant project lead. A simple tester register should be maintained with the tester's name, team, device model, Android version, date of access and testing responsibility. The register should not contain unnecessary personal information. The APK should be stored in a restricted project location with access limited to the approved testers. If a link is used, the link should not be publicly accessible and should be removed or replaced when the testing period ends. The project

team should avoid placing the APK in public repositories or unrestricted online storage. Testers should be informed that the APK is confidential to the project and should not be forwarded. They should also be told to report if the APK has been shared accidentally or if they notice an unexpected installation , application permission or suspicious behaviour.

Where possible, the team should provide each release candidate with a clear internal build label. This makes it easier to identify which testers received a particular version and which issues relate to that version.

VERSIONING & INFO ABOUT BUILD:

Versioning is important because several APKs may be created during the development and testing process. Each APK should have a unique and traceable build identity. The project team should record at least the following information:

- Application name.
- Application package name.
- Version name.
- Version code.
- Build number or release-candidate identifier.
- Git commit or branch used to create the build.
- Build date.
- Build environment.
- Backend or API environment.
- Android minimum supported version.
- Known limitations.
- Name of the person who created or approved the build.

A suitable internal file name could follow a format such as: FoodRemedy-android-rc01-v1.0.0-build001.apk

The exact format can be changed to match the team's existing conventions. The important point is that the file name should make the build easy to identify. The version

code should also increase for later builds so that the team can distinguish between different release candidates.

The project team should maintain a small release record for every distributed APK. This record should state who approved the build, who received it, which devices were tested and whether any known issues were identified. This will help the team avoid confusing an older APK with a newer release candidate.

AFTER INSTALLATION:

After installation, testers should complete a consistent set of checks. The testing process should begin with basic installation and launch checks before moving to application functionality. The tester should record the result of each test and include screenshots or screen recordings when an issue occurs.

For Food Remedy, useful checks may include:

1. Installing the APK successfully.
2. Registering or logging in using an approved test account.
3. Checking that the application connects to the expected backend.
4. Opening the application without a crash.
5. Checking profile-related functionality using test data.
6. Testing product search or product scanning where available.
7. Viewing product nutrition and allergen information.
8. Closing and reopening the application.
9. Testing shopping list or history functionality where included in the build.
10. Checking error messages when the network is unavailable.
11. Checking whether data remains consistent after restarting the application.
12. Recording any slow response, crash, incorrect data or unexpected behaviour.

The tester should not assume that a successful installation means that the application is ready for release. Installation only confirms that the package can be installed on the device. The application must still be tested for functionality, data handling, stability, compatibility and security.

The following evidence should be collected during physical-device testing:

Evidence item	Description
Device details	Device manufacturer, model and Android version
Build details	APK file name, version name, version code and build identifier
Installation result	Screenshot or written confirmation showing whether installation succeeded
Application launch	Screenshot showing that Food Remedy opened successfully
Login or registration	Evidence using an approved test account
Feature testing	Screenshots or notes for the features tested
Backend connection	Evidence that the application connected to the intended test environment
Error evidence	Screenshots, error messages or logs for failed tests
Performance observations	Notes about loading time, crashes, freezing or unexpected behaviour
Data consistency	Evidence of whether data remained correct after closing and reopening the app
Permissions	Record of permissions requested by the application
Final result	Pass, fail or requires further investigation, with a short explanation

The evidence should not include real passwords, private keys, unnecessary personal information or sensitive user data. Screenshots should be checked before being shared with the wider project team.

SUGGESTED INTERNAL TESTING WORKFLOW:

The recommended internal testing workflow is:

1. Development team prepares the signed release APK.
2. The build configuration and backend environment are checked.
3. The APK version and build identifier are recorded.
4. The APK is stored in a restricted project location.
5. The Research or Development Lead approves the tester list.
6. The APK and installation instructions are shared with authorised testers.
7. Testers install the APK using the approved source.
8. The team reviews the results and decides whether another build is required.
9. Testers complete the physical-device testing checklist.
10. Findings are reported to the relevant project team.
11. Testers record screenshots, errors and device details.
12. Old or superseded APKs are clearly marked and removed from the active testing location where appropriate.

This workflow provides a controlled process while still allowing the project to continue testing when Google Play access is unavailable or delayed.

SOME LIMITATIONS:

Direct APK distribution is useful as a fallback, but it does not provide all the benefits of Google Play testing. For example, direct distribution requires the project team to manage the APK file, tester access, installation instructions and version tracking manually. It may also provide less automated reporting and less controlled update delivery than a managed testing track. Direct APK installation also does not replace proper security testing, integration testing or release approval. It only provides a way to place the application on a physical Android device. The project team should still complete its normal testing, review and release processes before considering the application ready for wider distribution.

CONCLUSION:

This research identified that a signed APK can provide a practical fallback method for internal Android testing when Google Play testing access is unavailable or delayed. The process should be limited to authorised testers, use a restricted distribution method and include clear build identification and installation instructions. Testers should approve installation only from the specific source used to receive the APK and should keep Android security protections enabled. The project team should also protect signing keys, avoid including sensitive information in the build, use test accounts and record evidence from physical-device testing. For the Food Remedy, the recommended approach is to prepare a clearly labelled signed release APK, distribute it through a controlled internal channel and use a standard evidence checklist for each tester. This will allow the team to continue testing the Android release candidate while reducing the risks associated with uncontrolled APK distribution.

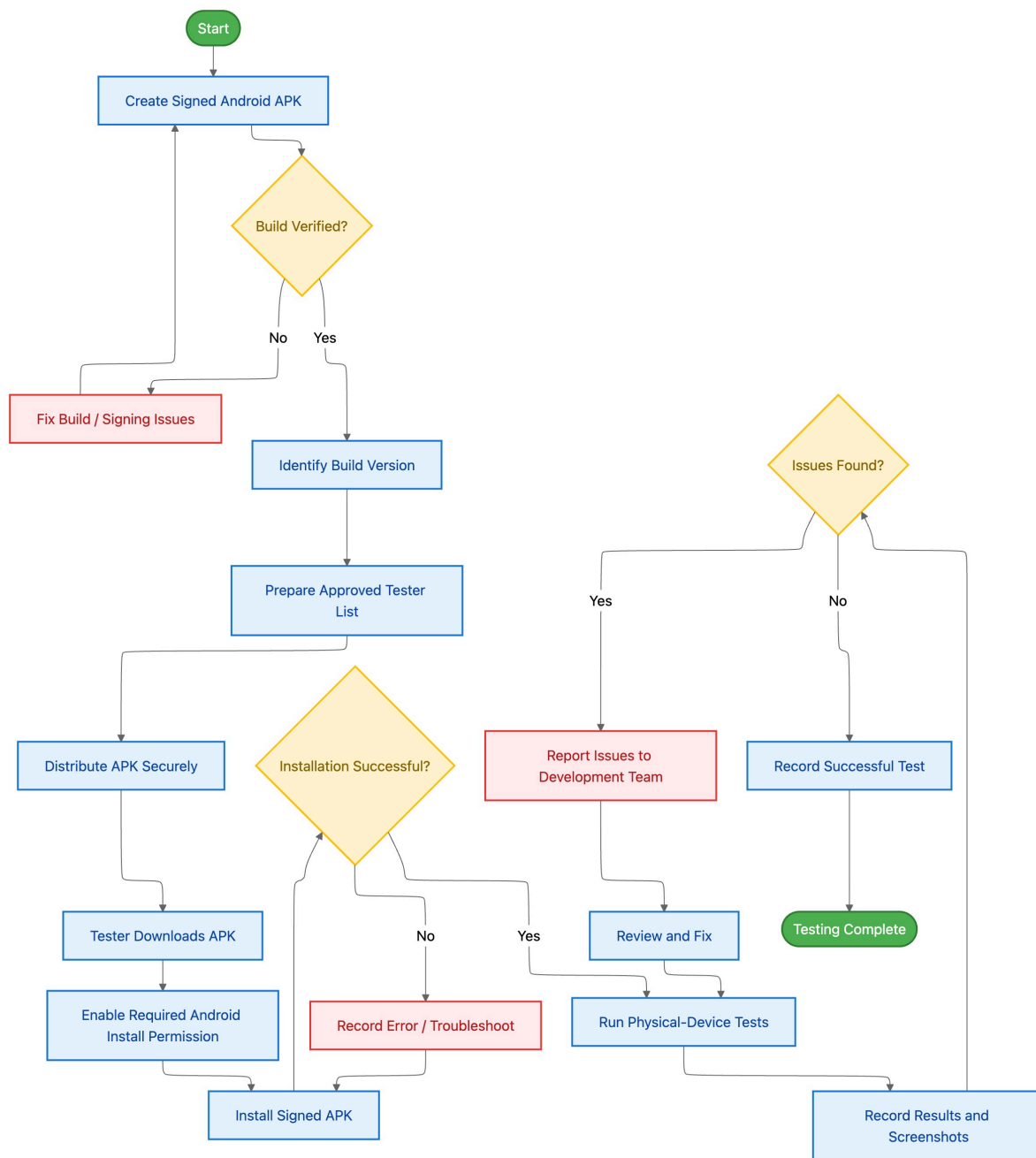


Fig 3 - Overall Flow

REFERENCES:

- Android Developers – Prepare your app for release:
<https://developer.android.com/studio/publish/preparing>

- Android Developers – Sign your app:
<https://developer.android.com/studio/publish/app-signing>
- Android Developers – Android App Bundle frequently asked questions:
<https://developer.android.com/guide/app-bundle/faq>
- Android Developers – The Android App Bundle format:
<https://developer.android.com/guide/app-bundle/app-bundle-format>
- Android Developers – apksigner: <https://developer.android.com/tools/apksigner>
- Google Play Console Help – Share app bundles and APKs internally:
<https://support.google.com/googleplay/android-developer/answer/9844679>
- Google Play Console Help – Set up an open, closed or internal test:
<https://support.google.com/googleplay/android-developer/answer/9845334>